

# Mapping ISO/IEC 27001 Controls to NIST CSF 2.0 Categories

Each of the 93 ISO/IEC 27001:2022 controls was intentionally assigned to one of the 22 NIST CSF 2.0 categories.

The objective of this mapping is to leverage the synergy between both approaches and to support a harmonized and practical application.

While many controls could reasonably be associated with more than one category, multiple assignments would reduce clarity and make the combined use of NIST CSF and ISO/IEC 27001 impractical.

Therefore, each control was mapped to the category that best reflects its primary purpose and functional intent.

For feedback or suggestions, please open an issue in this repository.

Jörg Pauloweit, 30.05.2026

© 2026 Jörg Pauloweit. All rights reserved.

| Category Identifier | NIST CSF 2.0 Categories                                 | German: NIST CSF 2.0 Kategorien                              | DIN EN ISO/IEC 27001:2023                                                                          |
|---------------------|---------------------------------------------------------|--------------------------------------------------------------|----------------------------------------------------------------------------------------------------|
| GV.OC               | Organizational Context                                  | Organisatorischer Kontext                                    | 5.8                                                                                                |
| GV.RM               | Risk Management Strategy                                | Strategie für das Risikomanagement                           | No Match                                                                                           |
| GV.RR               | Roles, Responsibilities, and Authorities                | Rollen, Zuständigkeiten und Befugnisse                       | 5.2 / 5.3 / 5.4 / 6.6                                                                              |
| GV.PO               | Policy                                                  | Richtlinie                                                   | 5.1 / 5.31 / 5.32 / 5.34 / 5.37 / 6.1 / 6.2 / 6.4 / 6.5 / 6.7 / 6.8                                |
| GV.OV               | Oversight                                               | Aufsicht                                                     | 5.5 / 5.6 / 5.24 / 5.27 / 5.35 / 5.36 / 8.30 / 8.32 / 8.34                                         |
| GV.SC               | Cybersecurity Supply Chain Risk Management              | Cybersicherheits-Risikomanagement in der Lieferkette         | 5.19 / 5.20 / 5.21 / 5.22                                                                          |
| ID.AM               | Asset Management                                        | Vermögensverwaltung                                          | 5.9 / 5.11                                                                                         |
| ID.RA               | Risk Assessment                                         | Risikobewertung                                              | 5.7                                                                                                |
| ID.IM               | Improvement                                             | Verbesserung                                                 | No Match                                                                                           |
| PR.AA               | Identity Management, Authentication, and Access Control | Identitätsmanagement, Authentifizierung und Zugangskontrolle | 5.15 / 5.16 / 5.17 / 5.18 / 7.1 / 7.2 / 7.3 / 7.4 / 8.2 / 8.3 / 8.4 / 8.5 / 8.18                   |
| PR.AT               | Awareness and Training                                  | Sensibilisierung und Schulung                                | 6.3                                                                                                |
| PR.DS               | Data Security                                           | Datensicherheit                                              | 5.10 / 5.12 / 5.13 / 5.14 / 5.23 / 5.33 / 7.9 / 7.10 / 8.10 / 8.11 / 8.12 / 8.13 / 8.24 / 8.33     |
| PR.PS               | Platform Security                                       | Platformsicherheit                                           | 8.1 / 8.7 / 8.8 / 8.9 / 8.19 / 8.25 / 8.26 / 8.28 / 8.29 / 8.31 /                                  |
| PR.IR               | Technology Infrastructure Resilience                    | Widerstandsfähigkeit der Technologieinfrastruktur            | 7.5 / 7.6 / 7.7 / 7.8 / 7.11 / 7.12 / 7.13 / 7.14 / 8.14 / 8.17 / 8.20 / 8.21 / 8.22 / 8.23 / 8.27 |
| DE.CM               | Continuous Monitoring                                   | Kontinuierliche Überwachung                                  | 8.6 / 8.15 / 8.16                                                                                  |
| DE.AE               | Adverse Event Analysis                                  | Analyse unerwünschter Ereignisse                             | 5.25                                                                                               |
| RS.MA               | Incident Management                                     | Management von Vorfällen                                     | 5.26                                                                                               |
| RS.AN               | Incident Analysis                                       | Analyse von Vorfällen                                        | 5.28                                                                                               |
| RS.CO               | Incident Response Reporting and Communication           | Berichterstattung und Kommunikation bei Vorfällen            | No Match                                                                                           |
| RS.MI               | Incident Mitigation                                     | Entschärfung von Vorfällen                                   | No Match                                                                                           |
| RC.RP               | Incident Recovery Plan Execution                        | Ausführung des Vorfall-Wiederherstellungsplans               | 5.29 / 5.30                                                                                        |
| RC.CO               | Incident Recovery Communication                         | Kommunikation zur Vorfall-Wiederherstellung                  | No Match                                                                                           |